

governing AI in HR

a readiness guide to the EU AI Act, NYC Local Law 144 and the documentation your HR systems must hold

8 chapters · 17 sources · entomo research

what is in this whitepaper

- 01 the obligations that already apply to your HR stack
- 02 why employment sits in Annex III of the EU AI Act
- 03 what the Digital Omnibus moved, and what it left alone
- 04 NYC Local Law 144: specifying a bias audit that holds up
- 05 the wider patchwork: California, Illinois, Colorado, Singapore, India
- 06 the documentation set to hold for every HR AI system
- 07 mapping to ISO /IEC 42001 and the NIST AI Risk Management Framework
- 08 a readiness plan to December 2027, quarter by quarter

the argument in short

On 8 July 2026 the European Union adopted Regulation (EU) 2026/1744, the Digital Omnibus on AI. It moved the application date for high-risk AI systems listed in Annex III from 2 August 2026 to 2 December 2027. Employment sits in Annex III, at point 4. A great many HR functions read that headline and concluded they had won eighteen months of quiet. That conclusion is wrong in three specific ways, and each way carries a number attached to it.

The first error is treating a schedule change as a scope change. The Omnibus moved dates inside one chapter of one regulation. It did not touch the prohibition on inferring emotions in the workplace, which has applied since 2 February 2025 and carries fines of up to EUR 35 000 000 or 7 percent of worldwide annual turnover. It did not touch the GDPR, whose Article 22 has constrained solely automated employment decisions since 2018. It did not reach German works council law, Spanish algorithmic transparency law, or the platform work directive that member states must transpose by 2 December 2026. It has no effect at all in New York City, Illinois, California, Singapore or India.

The second error is treating this as a vendor problem. Under the AI Act the employer is the deployer, and the deployer duties in Article 26 sit with the employer rather than the software company. Under New York City Local Law 144, the employer and not the vendor is responsible for ensuring a bias audit was done before the tool is used. In the United States, a federal court has allowed discrimination claims to proceed on the theory that a screening vendor can act as an agent of the employers who use it. Procurement cannot transfer these duties, and no contractual indemnity restores a missing record.

The third error is assuming that a policy counts as evidence. Every regime in this guide asks for documents with named fields. Logs kept for a defined minimum period. Records of which named person exercised oversight, on what date, and what they changed. Published audit summaries containing selection rates, impact ratios, the count of individuals in an unknown demographic category, and an explanation of the data source. Most enterprises can produce a responsible AI policy. Very few can produce that evidence for the systems already screening their candidates.

This guide sets out what applies now, what applies from December 2027, and what an HR function must be able to hand a regulator on request. It contains four named frameworks built to be used rather than admired: a classification test for deciding whether a given HR system is caught, a bias audit specification that goes beyond the statutory floor, an evidence register with defined fields and retention periods, and a readiness scoring model with a quarterly plan behind it. It is not legal advice, and decisions on your own systems should be taken with qualified counsel who know your facts.

this document is provided for general information. it is not legal, accounting or professional advice, and it does not create an advisory relationship.

the obligations that already apply to your HR stack

The high-risk deadline moved to December 2027. Several duties that reach HR systems did not move, and some have applied since early 2025.

There is a comfortable story circulating in HR technology governance. The European Union delayed its high-risk rules, so the compliance work can wait. The story survives by confusing one chapter of one regulation with the whole legal field.

Chapter II of the AI Act contains the prohibitions. It has applied since 2 February 2025 and the Digital Omnibus left it in place. Chapter III contains the high-risk requirements, and that is what moved to 2 December 2027. Nothing in the Omnibus touched the GDPR, national labour law, or any rule outside the European Union.

what already binds an employer in the EU

2 February 2025

the date the prohibition on inferring emotions in the workplace began to apply

Regulation (EU) 2024/1689, Article 113, 2024

Article 5(1)(f) prohibits the placing on the market, the putting into service for that purpose, or the use of AI systems to infer emotions of a natural person in the areas of workplace and education institutions. The only carve-out is use intended for medical or safety reasons. Article 99(3) sets the ceiling for breaching Article 5 at EUR 35 000 000 or 7 percent of total worldwide annual turnover for the preceding financial year, whichever is higher.

The Commission published guidelines on prohibited practices on 4 February 2025. They read workplace broadly, covering physical and virtual settings across the whole employment relationship, including recruitment and probation. Named examples of prohibited use include inferring emotion from facial expression during interviews, from voice patterns in contact centres, and from keystroke behaviour. The guidelines are non-binding, and only the Court of Justice of the European Union can interpret the regulation authoritatively.

THE DISTINCTION THAT DECIDES MOST CASES

The guidelines separate emotions from physical states. Detecting fatigue or pain is not emotion inference. Inferring stress, engagement, confidence, morale or burnout is. A wellbeing dashboard built on tone of voice, facial cues or typing rhythm sits on the prohibited side of that line, and calling it a wellbeing programme does not move it.

Article 4 requires providers and deployers to take measures to support AI literacy among staff who operate AI systems on their behalf. It has applied since 2 February 2025 and the Omnibus softened its wording from ensuring literacy to supporting its development. One honest qualification is worth making. Article 4 does not appear in the list at Article 99(4), so it is not directly subject to the 3 percent administrative fine. It remains a legal obligation and a supervisory expectation, but the enforcement route is indirect.

the duties that never depended on the AI Act

GDPR Article 22 gives a data subject the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects or similarly significantly affects them. Where one of the Article 22(2) exceptions applies, Article 22(3) still requires suitable safeguards, at minimum the right to obtain human intervention, to express a point of view, and to contest the decision. A rejection generated without a human in the loop engages this whether or not the AI Act has reached its high-risk date.

National labour law reaches further still. In Germany, section 87(1) no. 6 of the Works Constitution Act gives the works council co-determination over technical equipment capable of monitoring behaviour or performance, and the Federal Labour Court reads that capability objectively rather than by employer intent. Section 80(3), amended in 2021, treats an external expert as presumed necessary when the works council assesses the introduction of AI. In Spain, Article 64.4(d) of the Workers' Statute, added by Law 12/2021, obliges employers to inform worker representatives of the parameters, rules and instructions behind algorithms that affect working conditions and profiling.

Directive (EU) 2024/2831 on platform work must be transposed by 2 December 2026. Article 7 restricts automated processing of a worker's emotional or psychological state and of private conversations. Article 8 requires human oversight and provides that decisions to restrict, suspend or terminate an account are always taken by a human being. Article 9 requires detailed disclosure to workers and their representatives.

obligation	instrument	status
prohibition on emotion inference at work	AI Act Article 5(1)(f)	in force since 2 February 2025
AI literacy measures for staff	AI Act Article 4	in force since 2 February 2025
safeguards on solely automated decisions	GDPR Article 22	in force since 25 May 2018
co-determination on monitoring technology	national law, for example BetrVG 87(1) no. 6	in force, varies by member state
algorithmic transparency to worker representatives	Spain, Workers' Statute Article 64.4(d)	in force since 2021
platform work algorithmic management rules	Directive (EU) 2024/2831	transposition due 2 December 2026
deployer duties for high-risk HR systems	AI Act Article 26	applies from 2 December 2027
right to explanation of an individual decision	AI Act Article 86	applies from 2 December 2027

Outside the European Union the position is live rather than pending. New York City has enforced bias audit and candidate notice duties since 5 July 2023. California, Illinois and Colorado have each added employment-specific rules on automated decision systems. Singapore and India have moved through governance frameworks and data protection rules that reach employee data directly.

The Omnibus moved a date. It did not move a single duty out of the law, and it did not reach beyond the European Union at all.

The practical consequence is useful. An organisation that treats December 2027 as the start will spend most of 2027 discovering what it already owns, the slowest task in the programme. One that starts with the live obligations produces that inventory as a by-product.

why employment sits in Annex III of the EU AI Act

Annex III point 4 covers recruitment, task allocation, monitoring, promotion and termination. The drafting is wide and the escape route is narrow.

The AI Act classifies not by architecture but by the context of use and the consequences of getting it wrong. Employment appears in Annex III because access to work determines income, immigration status, housing and pension entitlement. A wrong output there is not a service inconvenience.

Annex III point 4(a) covers AI systems intended to be used for the recruitment or selection of natural persons, in particular to place targeted job advertisements, to analyse and filter job applications, and to evaluate candidates. Point 4(b) covers AI systems intended to be used to make decisions affecting terms of work-related relationships, the promotion or termination of work-related contractual relationships, to allocate tasks based on individual behaviour or personal traits or characteristics, or to monitor and evaluate the performance and behaviour of persons in such relationships.

how wide point 4 is in practice

Read against a typical enterprise HR stack, point 4 catches more than the recruiting module. The following are all within its plain wording.

- CV parsing, matching and candidate ranking, including where a human makes the final call
- targeted delivery of job advertisements to audience segments
- assessment scoring, structured interview scoring and video interview analysis
- shift, roster and task allocation that uses individual behaviour or personal traits
- continuous performance scoring, productivity indices and behaviour analytics
- attrition or flight-risk prediction that feeds retention, pay or promotion action
- internal mobility and succession recommendation engines
- workforce planning tools that identify individuals for redundancy selection

Article 6(3) provides a derogation. An Annex III system is not high-risk where it does not pose a significant risk of harm to health, safety or fundamental rights, including by not materially influencing the outcome of decision making. Four conditions can support that finding. The system performs a narrow procedural task. It improves the result of a previously completed human activity. It detects decision-making patterns or deviations from them without replacing or influencing the human assessment absent proper human review. It performs a preparatory task to a relevant assessment.

THE PROFILING OVERRIDE

Article 6(3) closes with a sentence that decides most HR cases. An Annex III system shall always be considered high-risk where it performs profiling of natural persons. GDPR Article 4(4) defines profiling to include automated processing to evaluate personal aspects, in particular to analyse or predict performance at work. Candidate scoring, potential ratings and flight-risk models meet that definition on their face.

the Annex III employment trigger test

Seven gates, answered in order and recorded in writing, that decide whether a given HR system is caught and what evidence you then owe.

01 gate 1, is it an AI system

Does it infer, from the inputs it receives, how to generate outputs such as predictions, recommendations or decisions? A rules engine applying thresholds a human wrote is generally outside. A model that learns weights from data is inside. Record which, and who decided.

02 gate 2, does it touch point 4

Does it advertise, filter, evaluate, allocate, monitor, promote, terminate or otherwise affect terms of work? If yes, the default is high-risk. Note the specific limb of point 4(a) or 4(b) engaged.

03 gate 3, does profiling apply

Does it evaluate personal aspects of an individual, in particular performance, reliability or behaviour? If yes, the Article 6(3) derogation is unavailable and gates 4 and 5 are skipped. Most HR scoring stops here.

04 gate 4, does a derogation genuinely fit

Test the four Article 6(3) conditions against how the system is used, not how it is sold. A shortlisting model that recruiters almost always follow is not a preparatory task. Evidence it with the rate at which humans depart from the output.

05 gate 5, document the derogation

Reliance on Article 6(3) must be documented before the system is put into service, and the provider must register it under Article 49(2). If you are relying on a vendor's derogation, obtain it and check that it describes your use.

06 gate 6, deployer or provider

You are the deployer if you use the system under your own authority. Article 25(1) makes you the provider instead if you put your name or trademark on it, substantially modify it, or modify its intended purpose so it becomes high-risk. Fine-tuning a vendor model on your own performance data engages all three.

07 gate 7, map the jurisdictions

Record every jurisdiction in which the system touches a candidate or employee. New York City, Illinois, California, Colorado, Singapore and India each attach separate duties.

Gate 6 is the one enterprises trip over, and the difference matters because the obligation sets are not comparable in size. Provider duties under Article 16 include a quality management system, technical documentation, conformity assessment, CE marking, registration in the EU database and a declaration of conformity. Deployer duties under Article 26 are narrower but non-delegable.

WHO OWES WHAT FOR A HIGH-RISK HR SYSTEM

duty	provider, Article 16	deployer, Article 26
quality management system and conformity assessment	yes	no
technical documentation and CE marking	yes	no
registration in the EU database	yes	public authority deployers only
use the system in accordance with the instructions for use	not applicable	yes, Article 26(1)
assign human oversight to competent, trained, authorised persons	design for it, Article 14	assign it, Article 26(2)
ensure input data is relevant and sufficiently representative	for training data, Article 10	where the deployer controls input data, Article 26(4)
retain automatically generated logs	Article 19	at least six months, Article 26(6)
inform workers' representatives and affected workers before use	no	yes, Article 26(7)
inform individuals that they are subject to the system	no	yes, Article 26(11)
carry out or feed the GDPR Article 35 impact assessment	supply information, Article 13	yes, Article 26(9)

Article 86 adds a right that HR functions should read carefully. An affected person subject to a decision taken by the deployer on the basis of the output of an Annex III high-risk system, other than a system under point 2, which produces legal effects or similarly significantly affects them adversely, may obtain from the deployer clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken. Employment is point 4, so it is squarely in scope. The right is residual and applies only to the extent it is not otherwise provided under Union law.

EUR 15 000 000 or 3%

the ceiling for a deployer's breach of Article 26, whichever is higher

Regulation (EU) 2024/1689, Article 99(4)(e), 2024

One duty most private employers do not carry is worth naming so that budget is not wasted on it. The fundamental rights impact assessment in Article 27 applies to deployers that are bodies governed by public law, private entities providing public services, and deployers of the systems at Annex III points 5(b) and 5(c). A private-sector employer is generally outside it. Article 26(9) nevertheless routes the same evidence into a GDPR Article 35 assessment, which most employers do owe.

Geography does not remove the question either. Article 2(1)(c) applies the regulation to providers and deployers established in a third country where the output produced by the AI system is used in the Union. A shared services centre in Bengaluru, Manila or Dubai screening applicants for a role based in Amsterdam is producing output used in the Union.

Procurement can move the invoice. It cannot move Article 26, which attaches to whoever uses the system under their own authority.

what the Digital Omnibus moved, and what it left alone

Regulation (EU) 2026/1744 changed dates and trimmed process. It left the substance of deployer duties and the right to explanation intact.

The Digital Omnibus on AI was signed on 8 July 2026, published in the Official Journal on 24 July 2026, and entered into force on 27 July 2026. Its full title records what it does: amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on artificial intelligence.

2 December 2027

the new application date for Annex III high-risk systems, including employment
Regulation (EU) 2026/1744, 2026

what moved

APPLICATION DATES BEFORE AND AFTER THE DIGITAL OMNIBUS

provision	original date	date after the Omnibus
Annex III high-risk systems, including employment	2 August 2026	2 December 2027
Annex I high-risk systems embedded in regulated products	2 August 2027	2 August 2028
Article 26 deployer duties for HR systems	2 August 2026	2 December 2027
Article 86 right to explanation	2 August 2026	2 December 2027
Article 50 transparency obligations	2 August 2026	unchanged
marking of synthetic content on systems already on the market	2 August 2026	2 December 2026
Article 5 prohibitions	2 February 2025	unchanged

Two practical failures drove the deferral, and both are worth understanding because they shape what compliance will look like when the date arrives. The first is standards. The Commission's standardisation request to CEN and CENELEC was amended in June 2025 and, as of mid-2026, no harmonised standard for the AI Act had been cited in the Official Journal.

0

harmonised AI Act standards cited in the Official Journal as of mid-2026

EU AI Act harmonised standards map, 2026

That number is not a technicality. Article 40(1) grants a presumption of conformity only for standards whose references have been published in the Official Journal under Regulation (EU) No 1025/2012. Until a citation happens, no organisation can demonstrate conformity by pointing at a standard, and every provider must argue its own case against the text of the regulation.

The second failure is institutional. Article 70 required member states to designate national competent authorities by 2 August 2025. A public tracker maintained through June 2026 recorded 9 member states with both market surveillance and notifying authorities clearly designated, 12 with partial designation, and 6 with none. An enforcement regime cannot begin before there is someone to enforce it.

what did not move

- the Article 5 prohibitions, including emotion inference at work, unchanged since 2 February 2025
- the general-purpose AI model obligations, in application since 2 August 2025
- the Article 50 transparency obligations, which took effect on 2 August 2026 as scheduled
- the Article 4 AI literacy duty, softened in wording but not in date
- the substance of Article 26 and Article 86, which the Omnibus did not amend

That last point is the one to carry into planning. The Omnibus rewrote Article 4, added paragraphs to Article 6, and amended Article 27 so that a fundamental rights impact assessment may cross-reference a data protection impact assessment rather than duplicate it. It did not change what a deployer of an HR system must do. The obligations you will owe on 2 December 2027 are the obligations you would have owed on 2 August 2026.

THE LEGACY QUESTION NOBODY HAS ANSWERED

Article 111(2) exempts high-risk systems already placed on the market before the application date unless they undergo significant changes in their designs. The phrase is undefined. HR platforms ship model retraining, prompt changes and scoring recalibrations continuously. Treating a system as grandfathered while its behaviour changes each quarter is a position you would have to defend, and no regulator or court has yet drawn the line.

Two other points are genuinely unsettled and should be recorded as such in any internal assessment. The Article 6(3) derogation has no case law behind it, so the boundary between a preparatory task and a materially influential one is untested. And the interaction between Article 86 and GDPR Article 15 is unresolved, because Article 86(3) applies only to the extent the right is not otherwise provided under Union law.



The date moved because the machinery was not ready. The duties did not change, which means the preparation you were going to do is the preparation you still have to do.

A reasonable planning stance follows. Treat 2 December 2027 as fixed, because the co-legislators removed the conditionality that the Commission had originally proposed and wrote firm dates into the amending regulation. Treat harmonised standards as unavailable until cited, and build your evidence against the articles themselves. Treat any grandfathering argument as a fallback rather than a plan.

NYC Local Law 144: specifying a bias audit that holds up

The rules specify the arithmetic precisely. Almost all of the difficulty lies in the data you are permitted to use.

Local Law 144 of 2021 took effect on 1 January 2023, and the Department of Consumer and Worker Protection began enforcing it on 5 July 2023. It prohibits employers and employment agencies from using an automated employment decision tool in New York City unless a bias audit was conducted within the previous year, a summary of the results is published, and candidates receive notice. Civil penalties run to 500 US dollars for a first violation and between 500 and 1 500 US dollars for each subsequent violation, with each day of unlawful use treated as a separate violation.

The territorial test surprises multinationals. The law applies where the job location is an office in New York City at least part of the time, or where the job is fully remote but the associated location is a New York City office. An employment agency located in the city is covered regardless. A recruiter in Singapore screening applicants for a New York-linked remote role is inside the law.

The definitional test is narrower than most people assume, and it is the first thing to get right. A tool is an AEDT only if it substantially assists or replaces discretionary decision making, which the rules define exhaustively.

1. relying solely on a simplified output such as a score, tag, classification or ranking, with no other factors considered
2. using a simplified output as one of a set of criteria where that output is weighted more than any other criterion in the set
3. using a simplified output to overrule conclusions derived from other factors, including human decision-making

what the audit must calculate

Where a tool selects candidates to move forward or classifies them into groups, the bias audit must calculate the selection rate for each category, calculate the impact ratio for each category, and perform those calculations separately across three cuts: sex categories, race and ethnicity categories, and intersectional categories of sex, ethnicity and race. It must also state the number of individuals assessed who fall in an unknown category and are therefore excluded.

Impact ratio is defined as the selection rate for a category divided by the selection rate of the most selected category. Where a tool produces scores rather than selections, the audit must first calculate the median score for the full sample, then the scoring rate for each category, which is the rate at which individuals in that category score above the sample median, then the impact ratio against the highest scoring category. The categories are the EEO-1 Component 1 categories.

WORKED EXAMPLE OF THE REQUIRED CALCULATION, ADAPTED FROM THE DCWP FINAL RULES

category	applicants	selected	selection rate	impact ratio
male	1390	667	48%	1.00
female	1181	555	47%	0.979
White, not Hispanic or Latino	797	412	52%	1.00
Black or African American, not Hispanic or Latino	390	170	44%	0.84
Hispanic or Latino male	205	90	43.9%	0.841
Native American or Alaska Native female	17	7	41.2%	0.789

The arithmetic is a descendant of the four-fifths rule at 29 CFR 1607.4(D), under which a selection rate below four-fifths of the highest rate is generally regarded by federal enforcement agencies as evidence of adverse impact. Local Law 144 requires the ratio to be calculated and published. It does not set a threshold, and it does not require the employer to do anything if the ratio is poor.

The data rules are where most audits fail. A bias audit must use historical data from actual use of the tool. Test data may be used only where insufficient historical data exists to conduct a statistically significant audit, and the summary must then explain why and describe how the test data was generated. An audit built on multiple employers' historical data may be relied on only if you contributed your own data to it, or if you have never used the tool.

THE CONSTRAINT THAT BREAKS MOST PROGRAMMES

DCWP is explicit that imputed or inferred demographic data cannot be used to conduct a bias audit. Many enterprises do not collect race and ethnicity from candidates outside the United States, and the common workaround of inferring it from names or images is not permitted here. Solving the audit therefore starts with lawful, voluntary demographic collection, which is itself constrained by GDPR Article 9 and by local law in every other jurisdiction you operate in.

the eight-point bias audit specification

A specification to hand an auditor or a vendor, written to satisfy Local Law 144 and to survive discovery in a discrimination claim.

01 1, scope statement

Name the exact tool, model version, configuration and score thresholds audited, plus the population and date range covered. An audit of a different model version is not an audit of your system.

02 2, auditor independence

Record that the auditor was not involved in using, developing or distributing the tool, holds no employment relationship with you or the vendor during the audit, and has no direct or material indirect financial interest in either.

03 3, the statutory calculations

Selection rate or scoring rate and impact ratio for every category, computed separately across sex, race and ethnicity, and intersectional cuts, plus the count of individuals in an unknown category.

04 4, calculations beyond the statute

Local Law 144 requires no age or disability analysis. Age is the characteristic on which the largest United States collective action over algorithmic screening currently turns. Add age band analysis, and add disability accommodation outcomes where lawful.

05 5, statistical honesty

State the sample size per cell, the confidence interval around each ratio, and every category excluded under the less-than-2-percent rule with the auditor's justification and that category's own rate. A ratio computed on 17 people is a number, not a finding.

06 6, data provenance

Record the data source, whether it is historical or test data, why test data was used if it was, how it was generated, and every other employer whose data was pooled.

07 7, threshold and action rule

Set in advance the ratio at which the tool is paused, re-weighted or withdrawn, and name the accountable executive. The law requires no such rule, which is why having one is evidence of good faith.

08 8, publication package

Publish the audit date, distribution date, source and explanation of the data, the unknown-category count, and the counts, rates and impact ratios for all categories, and keep it posted for six months after last use.

Two responsibilities are frequently misallocated. The vendor may commission an audit, but the employer is ultimately responsible for ensuring one was done before use. And DCWP enforces the audit and notice requirements only, referring discrimination claims to the New York City Commission on Human Rights. A clean audit is not a defence to a discrimination complaint.

Notice must be given at least ten business days before use, must state the job qualifications the tool will assess, and must include instructions for requesting a reasonable accommodation under other laws. Separately, the employer must publish its AEDT data retention policy, the type of data collected and its source, and answer written requests for that information within 30 days.

One caution on candour. In May 2026 a federal court in California accepted that AI bias-testing materials may attract attorney-client privilege where counsel directed the selection and curation of the data. That protection is fragile and depends on genuine legal direction. Testing you are required to publish is not privileged, and the underlying demographic data generally is not either.

A bias audit is a measurement, not a defence. It tells you what your tool is doing, and it creates a record of what you knew.

the wider patchwork: California, Illinois, Colorado, Singapore, India

the EU is the loudest regime, not the only one, and a multinational HR stack usually meets four or five at once.

An HR system bought once is deployed everywhere. The obligations attached to it are not uniform, and they do not arrive on a common timetable. A screening tool used in Bengaluru, Dubai, Singapore and Chicago sits inside four regimes that disagree about what must be disclosed, audited and retained.

This chapter covers the regimes most likely to reach an enterprise operating across Asia, the Gulf and the United States. All dates below were verified in September 2026. Two of them had already moved once, and one had moved twice, which is the main lesson of the chapter.

california: rules that already bind, with a four-year memory

California's Civil Rights Council approved employment regulations on automated decision systems on 27 June 2025. They took effect on 1 October 2025 and are enforced by the California Civil Rights Department.

Three features matter for an HR stack. The definition of an automated decision system is broad, covering any computational process that makes or assists in making an employment decision, so a ranking aid is in scope even when a human signs. Employment records including automated decision data must be kept for at least four years. And an assessment that elicits information about a disability, including a puzzle or game format, may constitute an unlawful medical inquiry.

THE QUIET ONE

The four-year retention rule is the obligation most often missed, because it lands on infrastructure rather than on process. If your vendor purges scoring data after twelve months, you cannot comply by changing a policy.

illinois: discriminatory effect, not intent

House Bill 3773 amended the Illinois Human Rights Act and took effect on 1 January 2026. It prohibits an employer from using artificial intelligence that has the effect of subjecting employees to discrimination on the basis of a protected class.

The prohibition reaches recruitment, hiring, promotion, renewal, selection for training or apprenticeship, discharge, discipline and tenure. Effect is the test, not intent, which means a tool can be unlawful without anyone having chosen a protected characteristic as an input. The Illinois Department of Human Rights is charged with rulemaking, and its first proposed notice rules were withdrawn and reissued, so the notice detail is still settling.

colorado: a cautionary tale about planning around a date

Colorado passed Senate Bill 24-205 in 2024, the first broad United States AI act, covering consequential decisions including employment. It was to apply from 1 February 2026.

It did not. Senate Bill 25B-004, signed on 28 August 2025 after a special session failed to agree amendments, postponed application to 30 June 2026. Then Senate Bill 26-189, signed on 14 May 2026, replaced the framework outright, with the new regime applying from 1 January 2027.

3 dates

application dates Colorado has published for essentially the same obligation, across a two-year period

Colorado General Assembly, 2024 to 2026

Any readiness plan anchored to a single statutory date is fragile. Anchor the plan to the capability instead. An organisation that can classify its systems, produce a bias audit and show a documentation trail is ready for whichever version survives.

singapore: voluntary, and the first to address agents

Singapore's Infocomm Media Development Authority launched a Model AI Governance Framework for Agentic AI on 22 January 2026. It is the first national framework written specifically for systems that plan and act rather than only predict.

Compliance is voluntary. Accountability is not. The framework's position is that organisations remain legally answerable for what their agents do, which is the same position the EU takes through deployer duties and the same one a court is likely to take without any AI statute at all. Its four dimensions, bounding risk upfront, keeping humans meaningfully accountable, implementing technical controls and enabling end-user responsibility, map closely onto the authority ladder set out in chapter three.

india: a data regime that reaches AI sideways

India has no employment AI statute. It has a data protection regime that constrains the same systems. The Digital Personal Data Protection Act 2023 was operationalised when the DPDP Rules 2025 were notified on 14 November 2025.

Compliance is phased across eighteen months, with the substantive obligations applying from 14 May 2027. For an HR stack the practical effects are consent and notice for personal data processing, purpose limitation that a repurposed model can breach, and security and breach obligations that cover training data as much as production data.

WHAT APPLIES WHERE, VERIFIED SEPTEMBER 2026

jurisdiction	instrument	status	applies from
European Union	AI Act, Annex III point 4	binding	2 December 2027 for standalone high-risk
European Union	AI Act, Article 5 emotion inference	binding	2 February 2025
New York City	Local Law 144	binding	5 July 2023, enforcement
California	Civil Rights Council ADS regulations	binding	1 October 2025
Illinois	HB 3773, Human Rights Act amendment	binding	1 January 2026
Colorado	SB 26-189, replacing SB 24-205	binding	1 January 2027
Singapore	IMDA Model AI Governance Framework for Agentic AI	voluntary	22 January 2026
India	DPDP Act 2023 and DPDP Rules 2025	binding, phased	14 May 2027 for substantive duties

the jurisdiction map

run this once per HR AI system, and rerun it when you enter a market or change a vendor.

01 where the person is

List every jurisdiction in which a candidate or employee subject to this system sits. Employment rules follow the worker, not the headquarters, and not the server.

02 where the decision lands

Identify the jurisdiction whose law governs the employment relationship affected. A shared services hub in one country routinely makes decisions governed by another.

03 what the system does

Classify against each regime's trigger. The EU asks whether it is high risk. New York asks whether it substantially assists a decision. California asks whether it makes or assists one. The thresholds differ, so classify separately rather than once.

04 what each regime demands

For every jurisdiction that bites, record the four obligations: disclose, audit, document, retain. Most regimes ask for some subset of those four.

05 the binding constraint

Take the strictest requirement in each of the four columns and build to that. Running one control set to the highest common standard is cheaper than running five.

THE PRACTICAL SHORTCUT

Build to the EU AI Act's deployer duties and New York's audit specification. An organisation that meets both is close to meeting California, Illinois and Colorado, because the underlying asks, disclosure, testing for disparate outcomes, documentation and retention, are the same four in different words.

before you deploy an HR AI system in a new market

- ☐ the jurisdiction map has been completed and dated for this system
- ☐ the strictest retention period across all applicable regimes is configured in the system, not in a policy document
- ☐ the vendor contract obliges disclosure of model changes that would invalidate an existing audit
- ☐ someone named owns the obligation to rerun classification when the law moves
- ☐ a diary entry exists for each published application date, with a review two quarters before it

The pattern across all five regimes is convergent even where the drafting is not. Each one wants to know what the system did, who was accountable, and whether a person could have intervened.

Build the record that answers those three questions and most of the compliance work is already done.

the documentation set to hold for every HR AI system

Regulators do not inspect intentions. They ask for records, and those records have named fields, named owners and minimum retention periods.

Almost every organisation that has written a responsible AI policy would fail a document request tomorrow. The policy is not the artefact any of these regimes asks for. What they ask for is narrower, more boring and much harder to produce after the fact.

Consider a realistic request. A rejected applicant asks, under Article 86, for an explanation of the role the system played. A works council asks which systems monitor performance and on what parameters. A regulator asks for three months of logs and the record of who exercised oversight. A plaintiff's counsel asks for every model version in use during the class period. Each is answered from a register or not at all.

the HR AI evidence register

One row per system per jurisdiction, with these fields populated before deployment and reviewed quarterly.

01 identity

System name, vendor, contract owner, model and version identifier, deployment date, and the date of the last material change to the model or its configuration. Version is the field most registers omit and the field litigation turns on.

02 classification

The completed Annex III employment trigger test, the limb of point 4 engaged, whether profiling is present, whether an Article 6(3) derogation is relied on and by whom, and your role as deployer or provider under Article 25.

03 jurisdictions

Every country, state and city in which the system touches a candidate or employee, with the specific instrument engaged in each. This is the field that determines the rest of the row.

04 provider documentation

The Article 13 instructions for use, including stated accuracy metrics, known limitations, the circumstances that degrade performance, the human oversight measures designed in, expected lifetime and maintenance requirements, and the log interpretation mechanism.

05 oversight record

The named individuals assigned under Article 26(2), evidence of their competence, training and authority, and a running log of interventions: outputs overridden, disregarded or reversed, with dates and reasons. Override rate is the single most useful governance metric you can hold.

06 data governance

Input data sources, the assessment of relevance and representativeness under Article 26(4), the lawful basis for processing, the retention schedule, and any Article 10(5) processing of special category data for bias detection with the documented justification that it was strictly necessary.

07 testing evidence

Every bias audit and validation exercise: date, auditor, independence statement, method, populations, results, and the action taken. Include the tests that produced acceptable results, not only the published ones.

08 transparency artefacts

The candidate or employee notice text and the date it was published, the worker representative notification under Article 26(7), the published bias audit summary and distribution date where applicable, and the standing explanation template used to answer Article 86 requests.

09 incidents and appeals

Serious incidents reported under Article 26(5), complaints, appeals, requests for human review, and outcomes. An empty incident log after two years of operation is itself a finding.

MINIMUM RETENTION AND PUBLICATION PERIODS BY INSTRUMENT

record	instrument	period
automatically generated system logs	AI Act Article 26(6)	at least six months, unless other law requires longer
employment records including automated decision system data	California employment regulations on automated-decision systems	four years
published bias audit summary and distribution date	NYC 6 RCNY 5-303(c)	posted at least six months after last use
response to a written request for AEDT data policy information	NYC 6 RCNY 5-304(d)	within 30 days of the request
provider technical documentation	AI Act Article 18	ten years after placing on the market

The six-month log floor in Article 26(6) is a floor and a poor planning target. It is expressed as a period appropriate to the intended purpose, of at least six months, unless other law provides otherwise. Employment limitation periods run for years, not months. A log that has aged out before a claim is filed protects nobody, least of all the employer who deleted it.

the pre-deployment gate: nothing goes live until every line is true

- ☐ the Annex III employment trigger test is complete, signed and dated
- ☐ the Article 13 instructions for use are held, read, and their accuracy claims recorded
- ☐ named oversight persons are appointed, trained, and hold documented authority to override
- ☐ the data protection impact assessment is complete and its residual risks accepted by a named executive
- ☐ worker representatives have been informed, and the consultation record is filed
- ☐ candidate and employee notices are published, with the ten business day clock started where NYC applies
- ☐ a bias audit within the last twelve months exists, and its published summary is live
- ☐ log retention is configured to the longer of six months and your longest employment limitation period
- ☐ the override and appeal route is built, staffed and tested with a real case
- ☐ the rollback plan names who can switch the system off and how long that takes

Two commercial asks belong in every HR technology contract from now on. The first is a right to the Article 13 instructions for use in a form you can hand to a regulator, updated on each material model

change. The second is notification of material model changes with enough lead time to re-test, because the vendor's release schedule now drives your Article 111 grandfathering position and your bias audit's currency.

ON TESTING AND DISCOVERABILITY

Bias testing creates a record of what you knew. That is the point of it, and it is also a litigation exposure. The answer is not to test less. It is to test on a schedule, act on the results, and record the action, so that the file shows an organisation that found a problem and fixed it rather than one that found a problem and filed it.

Ownership needs settling early, because the register spans functions that rarely share a system of record. HR owns the use case and the population. IT owns the version and the logs. Legal owns the classification and the jurisdictional mapping. Procurement owns the vendor evidence. In practice one accountable owner per row, with named contributors, works better than a committee.

The question is never whether you had a policy. It is whether you can produce the version, the logs and the name of the person who could have said no.

mapping to ISO/IEC 42001 and the NIST AI Risk Management Framework

Neither instrument makes you compliant with anything. Both give you a structure that auditors can test and regulators recognise.

Most enterprises reach for a management system standard at this point, and the instinct is sound. Statutory duties describe outcomes. A management system describes who does what, how often, and what evidence falls out. The two most used instruments are ISO/IEC 42001 and the NIST AI Risk Management Framework, and they do different jobs.

ISO/IEC 42001:2023 specifies requirements for an artificial intelligence management system. It follows the familiar clause structure of ISO management standards and carries 38 reference controls in Annex A, organised under nine areas numbered A.2 to A.10, covering AI policy, internal roles, resources, impact assessment, the system lifecycle, data, information for interested parties, responsible use, and third-party relationships. Annexes B, C and D are informative guidance rather than requirements. Organisations can be certified against it by accredited bodies.

Two companion standards matter for HR specifically. ISO/IEC 42005:2025, published in April 2025, gives a method for AI system impact assessment, which maps closely onto what a data protection impact assessment must cover for an HR system. ISO/IEC 23894:2023 provides guidance on AI risk management and connects the AI-specific work to the enterprise risk framework you already run.

The NIST AI Risk Management Framework 1.0 was published on 26 January 2023 as NIST AI 100-1. It is voluntary and organises work into four functions, GOVERN, MAP, MEASURE and MANAGE, against seven characteristics of trustworthy AI: valid and reliable, safe, secure and resilient, accountable and transparent, explainable and interpretable, privacy enhanced, and fair with harmful biases managed. It is a vocabulary and a structure rather than a certifiable standard.

MAPPING STATUTORY HR DUTIES TO THE TWO FRAMEWORKS

duty	ISO/IEC 42001 area	NIST AI RMF function	artefact it produces
classify the system and decide if it is high-risk	A.5 impact assessment	MAP	completed trigger test, signed
assign competent human oversight	A.3 internal organisation	GOVERN	named roles, training records, override log
ensure input data is relevant and representative	A.7 data for AI systems	MAP and MEASURE	data provenance and representativeness note
detect and mitigate bias	A.6 AI system lifecycle	MEASURE	bias audit with impact ratios and action taken
inform workers and their representatives	A.8 information for interested parties	GOVERN	notice text, publication date, consultation record
explain an individual decision	A.9 responsible use	MANAGE	explanation template and issued responses
monitor in operation and report incidents	A.6 AI system lifecycle	MANAGE	monitoring plan, incident log, logs retained
manage the vendor relationship	A.10 third-party relationships	GOVERN	contract clauses, instructions for use, change notices

WHAT A CERTIFICATE DOES NOT BUY

An ISO/IEC 42001 certificate is not a presumption of conformity with the AI Act. Article 40(1) grants that presumption only to harmonised standards whose references have been published in the Official Journal, and as of mid-2026 none had been. A certificate is credible evidence of a functioning management system. It is not a defence, and a vendor offering it as one should be asked a follow-up question.

A second caution applies to NIST. Under the United States AI Action Plan of July 2025, NIST was tasked with revising the AI RMF to remove references to misinformation, diversity, equity and inclusion, and climate change. An organisation that has hard-coded its control set to the text of version 1.0 will find the reference moving underneath it. Anchor to your own control library and cite the framework as a mapping, not as the source of truth.

The practical sequence that works is unglamorous. Build the register first, because it is the input to everything. Map each register field to a control in whichever framework you have adopted. Run the impact assessment method from ISO/IEC 42005 on your three highest-volume HR systems. Only then decide whether certification is worth the cost, which usually depends on whether customers or works councils are asking for it.



A framework will not tell you whether your screening tool is lawful. It will tell you who was supposed to check, and whether they did.

a readiness plan to December 2027, quarter by quarter

Five quarters remain. The inventory and the vendor evidence take longest, so both start now rather than after the policy work.

The gap between an organisation that is ready in December 2027 and one that is not will not be the quality of its policy. It will be whether it knows what it owns. Inventory work in a large HR estate routinely takes two quarters, because shadow tools sit inside business units and inside modules of platforms nobody classified as AI.

the workforce AI readiness index

Five dimensions, twenty points each, scored per business unit and reviewed quarterly against a target of 80 by September 2027.

01 inventory, 20 points

Score 4 for a list of HR systems, 8 for a list with vendors and owners, 12 for completed classification tests, 16 for model versions and change history, 20 for shadow tools discovered through a formal sweep rather than a survey.

02 classification, 20 points

Score 4 if someone has read Annex III, 8 if high-risk systems are identified, 12 if the deployer or provider question is answered per system, 16 if derogations are documented and defensible, 20 if the classification is re-run on each material model change.

03 evidence, 20 points

Score 4 for a policy, 8 for instructions for use held, 12 for oversight and override logs running, 16 for log retention configured to the longer period, 20 for a register that can answer a document request within five working days.

04 measurement, 20 points

Score 4 for no testing, 8 for vendor-supplied test results, 12 for an independent audit of the highest-volume tool, 16 for audits across all in-scope tools within twelve months, 20 for pre-agreed thresholds with a documented action taken at least once.

05 people, 20 points

Score 4 for training slides, 8 for named oversight roles, 12 for oversight roles with documented authority to override, 16 for worker representatives informed and consulted, 20 for a tested appeal route with published response times.

A score below 40 means the programme has not started, whatever the steering committee minutes say. Between 40 and 65 the organisation can describe its systems but cannot evidence their

operation. Above 80 a document request is an inconvenience rather than an incident.

QUARTERLY PLAN TO 2 DECEMBER 2027

quarter	objective	output
Q4 2026	know what you own and stop the prohibited uses	complete HR AI inventory, Article 5 sweep for emotion inference, decommission or exception every hit
Q1 2027	classify and assign	trigger test run on every system, deployer or provider decided, accountable owner named per row
Q2 2027	get the vendor evidence	Article 13 instructions for use obtained, contract change notices agreed, gaps escalated or systems replaced
Q3 2027	measure and oversee	independent bias audits complete, oversight roles staffed and trained, override and appeal routes live
Q4 2027	prove it works	full register operational, notices and worker consultation complete, dry-run document request against a real system

Two sequencing errors are common enough to name. The first is starting with the policy, which produces a document nobody can operationalise because it was written before anyone knew what the estate contained. The second is starting with the highest-risk system, which is usually the one with the most vendor resistance, and stalling there. Start with the highest-volume system instead, because volume is where exposure accumulates and where the data for a statistically meaningful audit exists.

Resourcing is smaller than most people fear if the work is properly scoped. The inventory and register are a programme manager and an analyst for two quarters. The classification work is legal time measured in days per system, not weeks. Independent bias audits are procured. The item that consistently gets under-resourced is the oversight function itself, because Article 26(2) requires competence, training and authority, and authority means the reviewer must be senior enough to overturn a hiring manager.

what done looks like on 1 December 2027

- ☐ every HR AI system is on the register with a completed, signed classification
- ☐ no system in the estate infers emotional state from voice, face, text or keystrokes
- ☐ instructions for use are held for every high-risk system and match the version deployed
- ☐ named oversight persons hold written authority to override, and the override log is not empty
- ☐ logs are retained for the longer of six months and your longest employment limitation period
- ☐ workers and their representatives have been informed before use, with the record filed
- ☐ an explanation template exists and has been used to answer a real Article 86 request
- ☐ bias audits are current within twelve months for every tool that requires one
- ☐ a documented decision exists for every system you chose not to classify as high-risk

A NECESSARY NOTE

This guide is not legal advice. It sets out publicly available law and official guidance as at September 2026, with sources listed so that every statement can be checked at source. Regulation in this area is moving, several provisions described here are untested, and decisions about your own systems should be taken with qualified counsel who know your facts.

The organisations that will find December 2027 straightforward are not the ones with the most sophisticated AI. They are the ones that treated the AI Act's deployer duties as an operating discipline rather than a legal project, and that started the inventory before they had finished arguing about the policy.

Readiness is not a document. It is the ability to answer, within a week, what the system did, who checked it, and what happened when someone disagreed.

REFERENCES

sources

every figure in this document traces to one of the following. links were live at the date of publication.

- 1 Regulation (EU) 2024/1689, the EU AI Act, 2024
<https://eur-lex.europa.eu/eli/reg/2024/1689/oj>
- 2 EU AI Act, Annex III high-risk systems including employment, 2024
<https://artificialintelligenceact.eu/annex/3/>
- 3 EU AI Act, Article 14, human oversight, 2024
<https://artificialintelligenceact.eu/article/14/>
- 4 EU AI Act, Article 26, obligations of deployers, 2024
<https://artificialintelligenceact.eu/article/26/>
- 5 EU AI Act, Article 86, right to explanation of individual decision-making, 2024
<https://artificialintelligenceact.eu/article/86/>
- 6 Regulation (EU) 2026/1744, Digital Omnibus on AI, 2026
<https://eur-lex.europa.eu/eli/reg/2026/1744/oj>
- 7 NYC Department of Consumer and Worker Protection, Automated Employment Decision Tools, 2023
<https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page>
- 8 NYC Rules, Automated Employment Decision Tools, 2023
<https://rules.cityofnewyork.us/rule/automated-employment-decision-tools-2/>
- 9 Wright, Muenster, Vecchione et al., Null Compliance: NYC Local Law 144, ACM FAccT, 2024
<https://arxiv.org/abs/2406.01399>
- 10 California Civil Rights Council, employment regulations on automated decision systems, final text, 2025
<https://civildrights.ca.gov/wp-content/uploads/sites/32/2025/06/Final-Text-regulations-automated-employment-decision-systems.pdf>
- 11 Illinois HB 3773, Human Rights Act amendment on AI in employment, effective 2026
<https://natlawreview.com/article/illinois-anti-discrimination-law-address-ai-goes-effect-1-january-2026>
- 12 Colorado General Assembly, SB 24-205 Consumer Protections for Artificial Intelligence, 2024
<https://leg.colorado.gov/bills/sb24-205>
- 13 Colorado General Assembly, SB 25B-004 postponing the Colorado AI Act, 2025
<https://leg.colorado.gov/bills/sb25b-004>
- 14 IMDA Singapore, Model AI Governance Framework for Agentic AI, 2026
<https://www.imda.gov.sg/resources/press-releases-factsheets-and-speeches/press-releases/2026/new-model-ai-governance-framework-for-agentic-ai>
- 15 Ministry of Electronics and Information Technology, India, DPDP Rules 2025 notified, 2025
<https://www.pib.gov.in/PressReleasePage.aspx?PRID=2190655®=48&lang=2>

16 NIST, AI Risk Management Framework 1.0, 2023
<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf>

17 ISO/IEC 42001, AI management systems, 2023
<https://www.iso.org/standard/81230.html>

about entomo

entomo is an agentic workforce intelligence platform for performance, skills, and talent decisions, used by more than 30 million people worldwide. its agents reason on axon, a living model of work that connects what every role requires with what every person brings, benchmarked against the market and refreshed every month.

the practice behind this document is the same one behind the platform: HR process depth first, intelligence second.

see it against your own hardest role

entomo.co

